



**Northeastern
University**

Open-Source Security Scanner

Capstone Project Presentation

CY7900 – Capstone Project

Group Members

Kevin Dsouza 001587656
Rohan Tergaonkar 002195690
Hemal Maniar 001566400
Tejas Kulkarni 001090758



**Northeastern
University**

Project Requirement

- ❖ Northeastern ITS requires an open-source solution to avoid its reliance on proprietary software
- ❖ Northeastern ITS wanted a custom solution to fit their specific requirements
- ❖ A scalable alternative that does not require increments financially
- ❖ Alternative that is supported by research and regularly updated to reflect recent advances



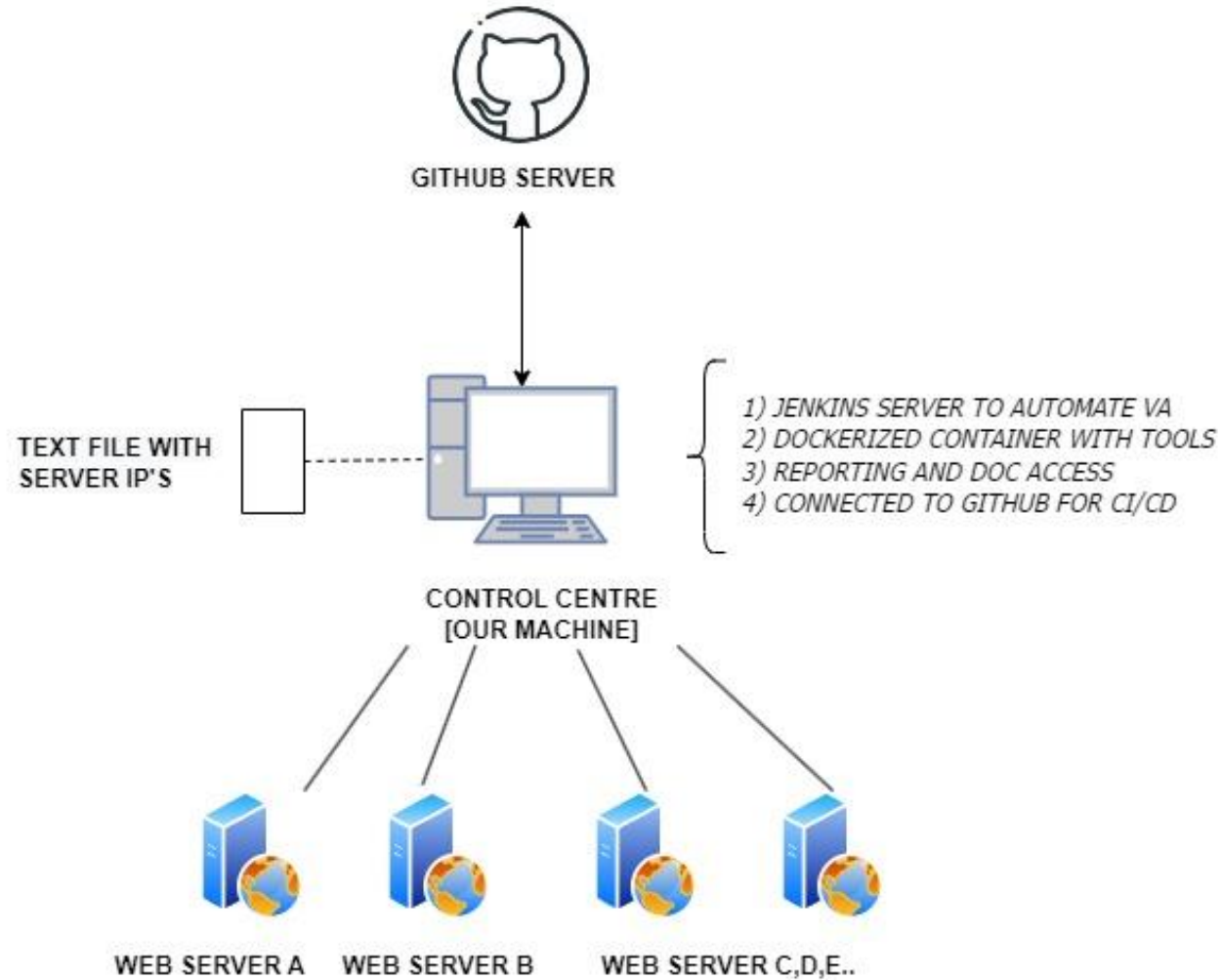
**Northeastern
University**

Project Deliverables

- ❖ Developed solution pre-installed installed on a Northeastern ITS instance
- ❖ Pre-configured pipeline and access to pipeline that triggers the solution
- ❖ Documentation to support use cases of the solution and tools in the solution



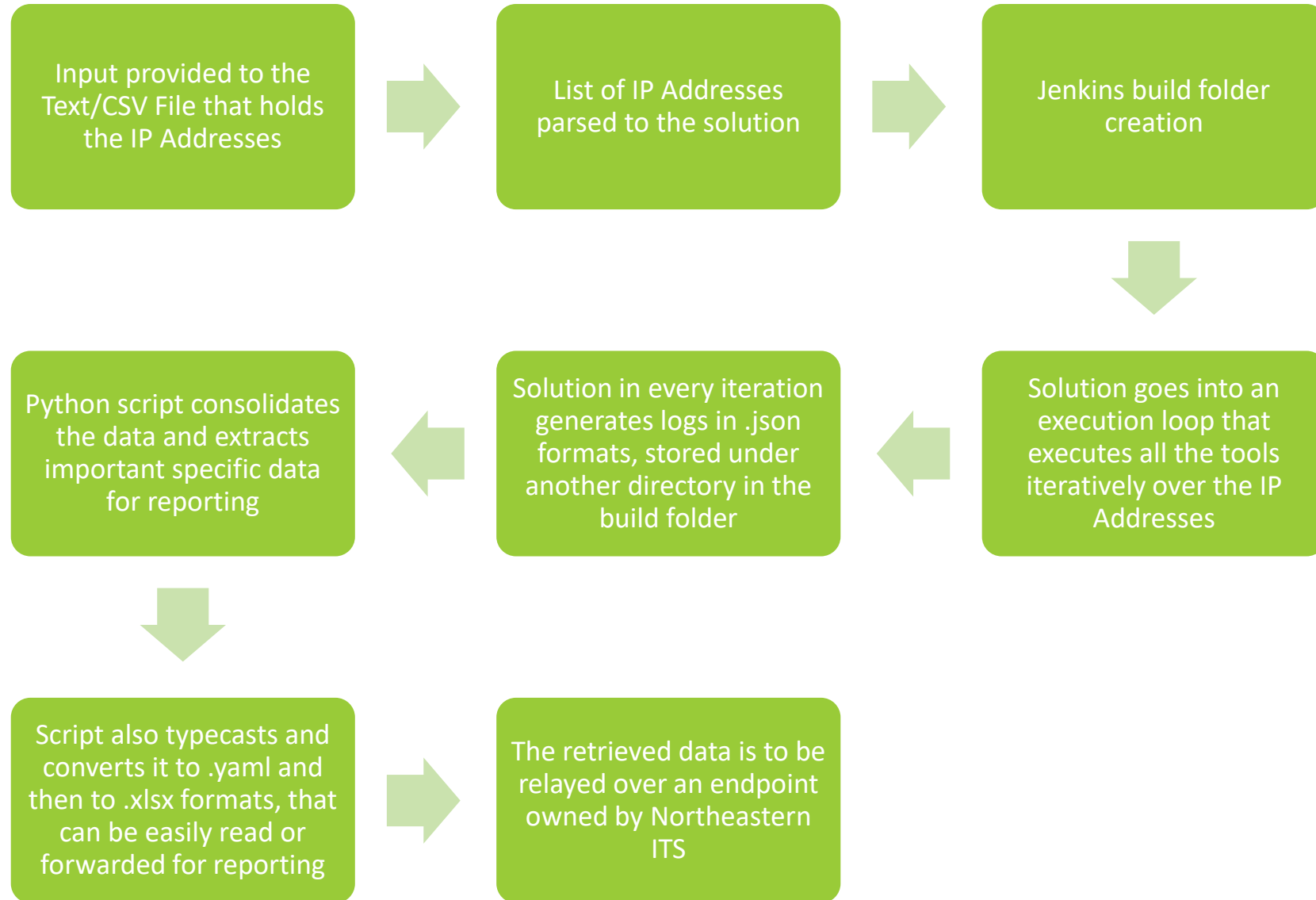
Northeastern
University

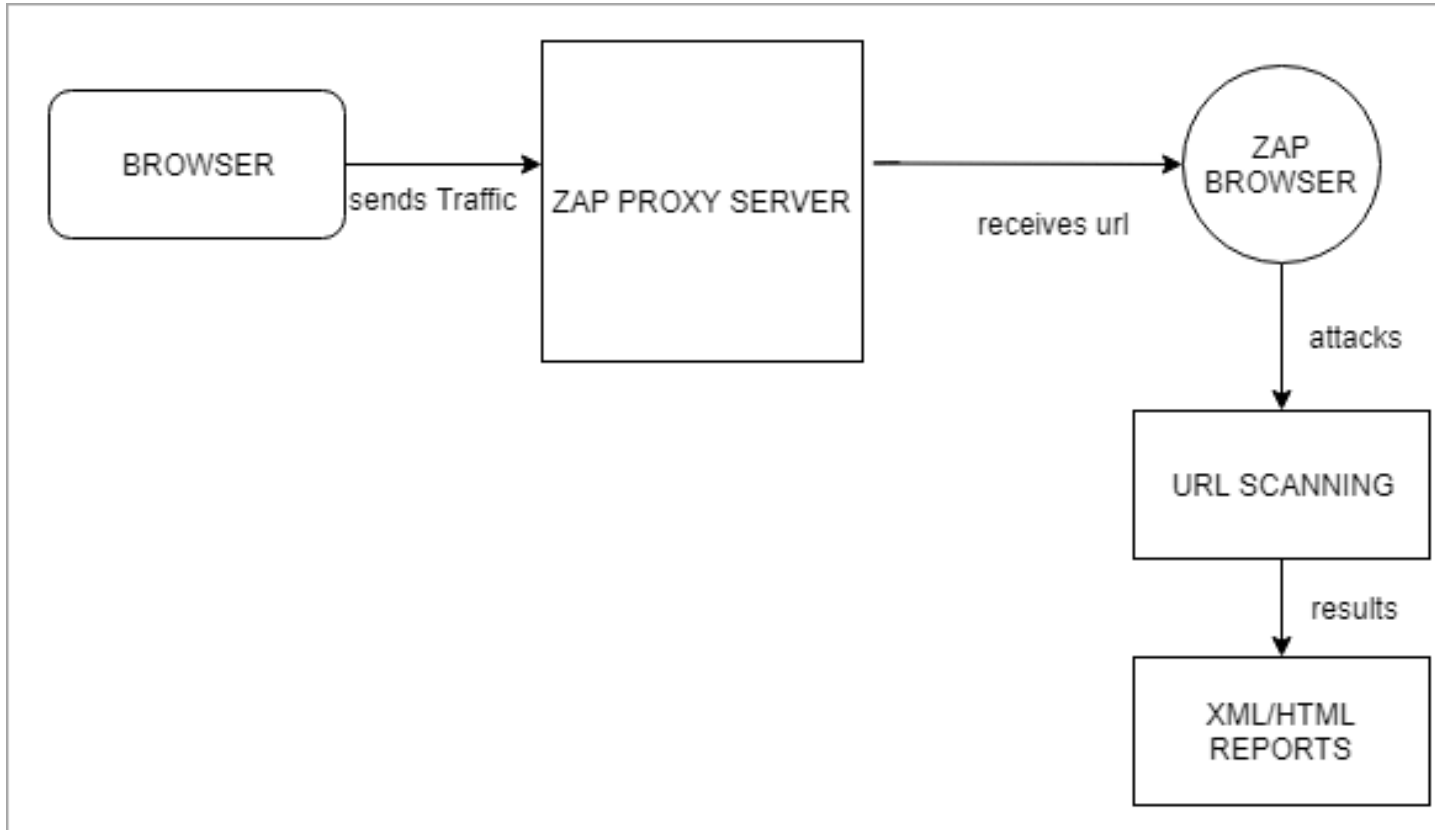


Devised Architecture



**Northeastern
University**





Reference: <https://www.softwaretestinghelp.com/owasp-zap-tutorial/>

Tools selected

❖ OWASP ZAP

- ❖ Uses a Browser to direct web traffic through a proxy server
- ❖ Attacks and scans that url/s based on defined context and generates results
- ❖ Open-source alternative to industry leaders like Veracode, Qualys WAS etc.



```
root@bt: /pentest/web/nikto
File Edit View Terminal Help
# nikto -h 192.168.18.132 -p 80,443

-----
+ No web server found on 192.168.18.132:443
-----
+ Target IP:      192.168.18.132
+ Target Hostname: 192.168.18.132
+ Target Port:    80
+ Start Time:     2013-02-24 12:27:27 (GMT-5)
-----
+ Server: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.2.19). Apache 1.3.42
  (final release) and 2.0.64 are also current.
+ PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 5.3.6)
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST
+ Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10
+ OSVDB-3233: /phpinfo.php: Contains PHP configuration information
+ OSVDB-3268: /icons/: Directory indexing found.
+ OSVDB-3233: /icons/README: Apache default file found.
+ OSVDB-40478: /tikiwiki/tiki-graph_formula.php?w=1&h=1&s=1&min=1&max=2&f[]=x.tan.phpinfo
  ()&t=png&title=http://cirt.net/rfiinc.txt?: TikiWiki contains a vulnerability which allow
  s remote attackers to execute arbitrary PHP code.
+ 6474 items checked: 2 error(s) and 9 item(s) reported on remote host
+ End Time:      2013-02-24 12:28:20 (GMT-5) (53 seconds)
-----
+ 1 host(s) tested
root@bt:/pentest/web/nikto#
```

Reference: <https://www.sciencedirect.com/topics/computer-science/nikto>

Tools selected

❖ Nikto

- ❖ Scans the web application and web servers both
- ❖ Nikto checks over 6700 potentially dangerous files/programs, checks for outdated versions of over 1250 servers, and version specific problems on over 270 servers
- ❖ Uses plugins from other tools that self update regularly



```
dirks@laptop:~|130% testssl.sh --mx google.de
No mapping file found

#####
testssl.sh      2.6 from https://testssl.sh/
(1.379 2015/09/15 06:48:58)

  This program is free software. Distribution and
  modification under GPLv2 permitted.
  USAGE w/o ANY WARRANTY. USE IT AT YOUR OWN RISK!

  Please file bugs @ https://testssl.sh/bugs/

#####

Using "OpenSSL 1.0.1k 8 Jan 2015" [~111 ciphers] on
-----/usr/bin/openssl
(built: "May 26 15:55:15 2015", platform: "linux-x86_64")

Testing now all MX records (on port 25): aspmx.l.google.com alt1.aspmx.l.google.com alt2.aspmx.l.google.com alt3.aspmx.l.google.com alt4.aspmx.l.google.com
-----
Testing now (2015-09-15 21:03) --> 173.194.65.26:25 (aspmx.l.google.com) <--
-----
further IP addresses: 2a00:1450:4013:c01::1a
rDNS (173.194.65.26): ee-in-f26.1e100.net.
Service set:         STARTTLS via SMTP

--> Testing protocols (via openssl, SSLv2 via sockets)

SSLv2      not offered (OK)
SSLv3      offered (NOT ok)
TLS 1      offered
TLS 1.1    offered
TLS 1.2    offered (OK)
SPDY/NPN   (SPDY is a HTTP protocol and thus not tested here)

--> Testing -standard cipher lists

Null Ciphers      Local problem: No Null Ciphers configured in /usr/bin/openssl
Anonymous NULL Ciphers  not offered (OK)
Anonymous DH Ciphers   not offered (OK)
40 Bit encryption     not offered (OK)
56 Bit encryption     Local problem: No 56 Bit encryption configured in /usr/bin/openssl
Export Ciphers (general) not offered (OK)
Low (<=64 Bit)        not offered (OK)
DES Ciphers          not offered (OK)
Medium grade encryption offered (NOT ok)
Triple DES Ciphers   offered (NOT ok)
High grade encryption offered (OK)
```

Reference: <https://testssl.sh/>

Tools selected

❖ TestSSL

❖ Scans on service levels not just

Port 443 scans unlike most
available alternatives

❖ Reliable and Private, no vendor

intervention, all instances are
unique to your implementation



**Northeastern
University**

Tool Advantages

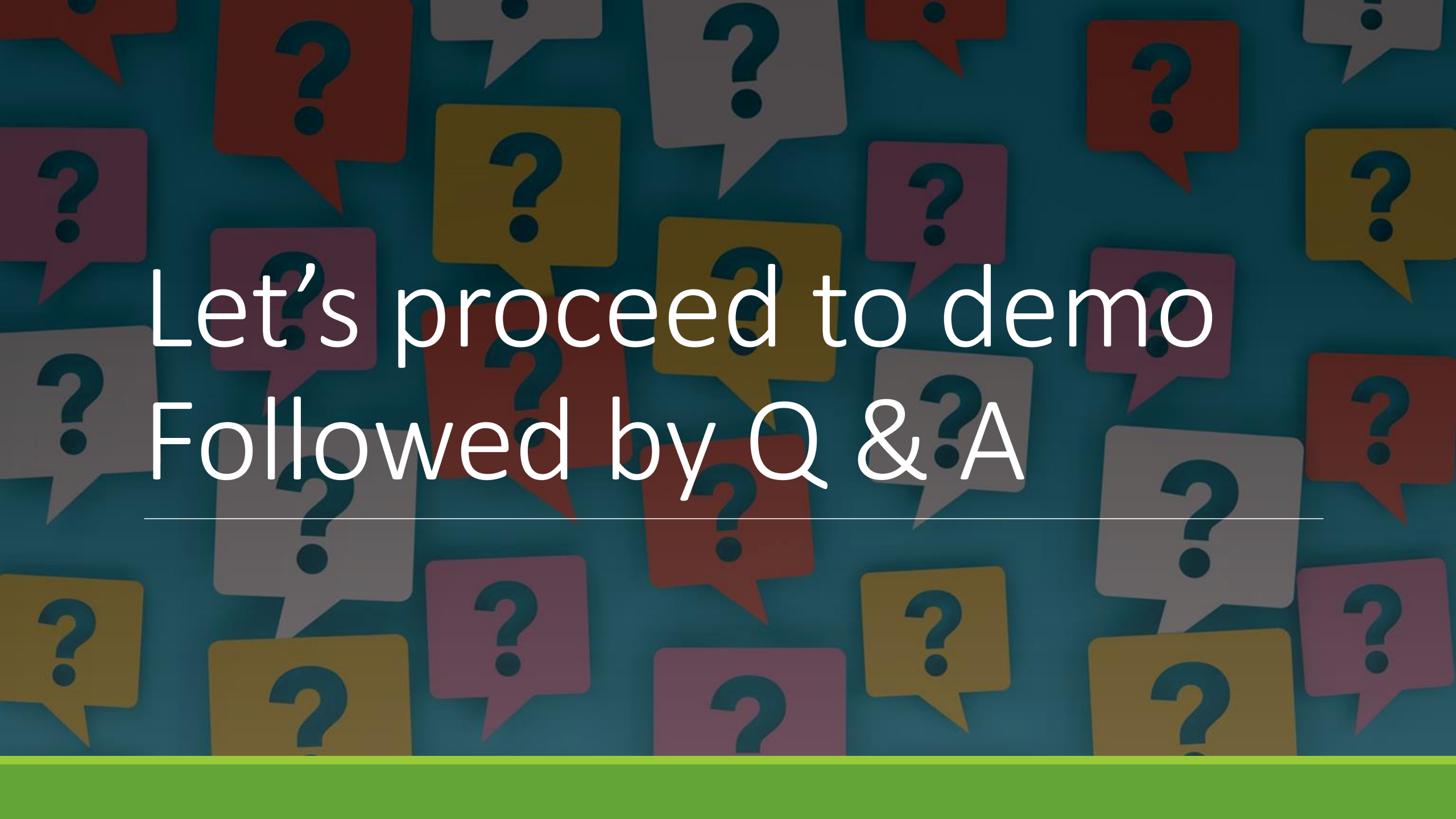
- ❖ Optimally scalable and can be scaled up to scan as many nodes as required
- ❖ Tool and Add-on ready, simple commands need to be added to Jenkins to facilitate implementation
- ❖ Simple reporting easy to perceive and organize
- ❖ Flexible and enhances specific uses
- ❖ No third-party interference, all instances are unique to implementation and data stored in environment



**Northeastern
University**

Future Scope and Avenues (to be facilitated by the client)

- ❖ Configuring the solution with Microsoft Sentinel Reporting actively used by Northeastern ITS
- ❖ Execution of the solution across the actual environment beyond sandbox testing
- ❖ Continuous monitoring of the tools to improve latency and processing
- ❖ Exporting open-source solution to the community for leveraging actual industrial use

The background of the slide is a dark teal color, overlaid with a pattern of numerous speech bubbles. Each speech bubble is a different color (including shades of red, orange, yellow, green, and blue) and contains a white question mark. The bubbles are scattered across the entire background, creating a textured, question-themed effect.

Let's proceed to demo
Followed by Q & A
